

SEC1516

Lab Guide

Table of Contents

Prerequisites	2
Troubleshooting Connectivity	2
Access the Lab Environment	3
Description	3
Login to Splunk Show	3
Finding Your Instance Details:	5
Exercise 1 – Dashboard Familiarization and Risk Score Analysis	6
Description	6
Steps	6
Exercise 2 – Password Spray Attack Detection	9
Description	9
Steps	9
Exercise 3 – Credential Access: Kerberoasting	12
Description	12
Steps	12
Exercise 4 – Rare Process Execution (Tooling)	13
Description	13
Steps	13
Exercise 5 – Privilege Escalation and Abnormal Admin Activity	15
Description	15
Steps	15
Exercise 6 – Data Exfiltration	16
Description	16
Steps	16
Summary	18

Prerequisites

Splunk's hands-on workshops are delivered via the [Splunk Show portal](#) - **you will need a splunk.com account in order to access this.**

If you don't already have a Splunk.com account, please create one [here](#) before proceeding with the rest of the workshop.

Troubleshooting Connectivity

If you experience connectivity issues with accessing either your workshop environment or the event page, please try the following troubleshooting steps. If you still experience issues please reach out to the team running your workshop.

- **Use Google Chrome** (if you're not already)
- If the event page (i.e. [https://splunk.show/...](https://splunk.show/)) didn't load when you clicked on the link, try **refreshing the page**
- **Disconnect from VPN** (if you're using one)
- **Clear your browser cache and restart your browser** (if using Google Chrome, go to: Settings > Privacy and security > Delete browsing data)
- **Try using private/incognito browsing mode** to rule out any caching issues

Need help?

If you're still experiencing issues please ask a member of the onsite support team for assistance and they'll help get you up and running!

Access the Lab Environment

Description

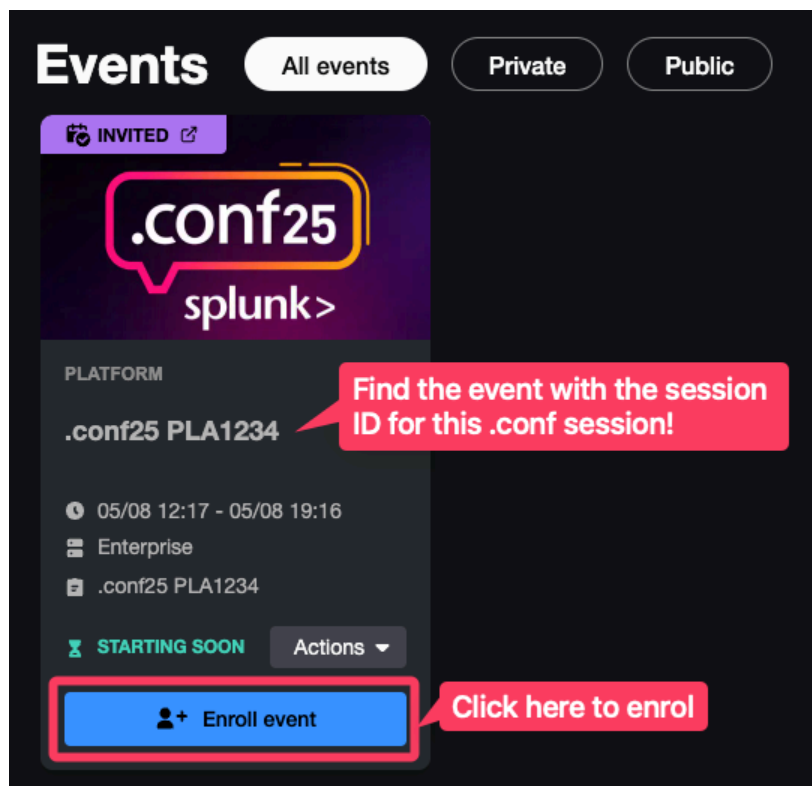
In this exercise, you will access your lab environment using our [Splunk Show portal](#).

Login to Splunk Show

You should have received an invite email from **Splunk Show** containing a link to a workshop event (“<https://splunk.show/...>”)

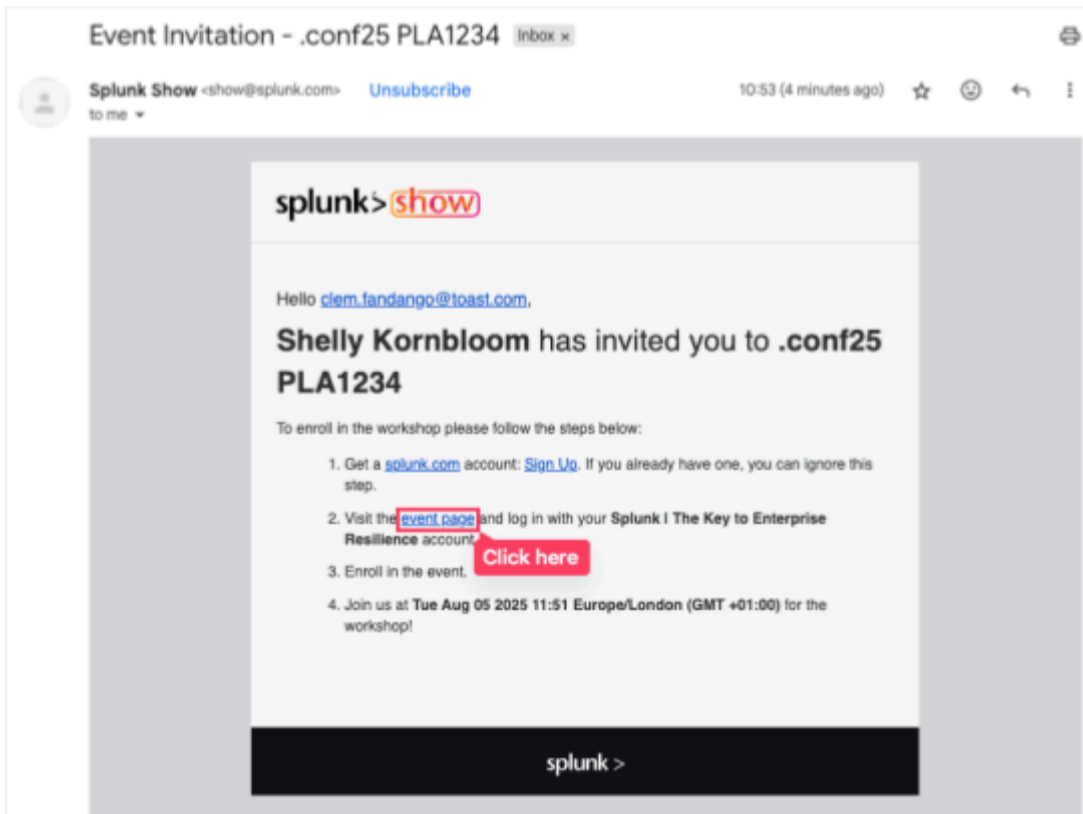
✗ If you **DON'T** have an email from Splunk Show:

1. Please check your spam folder.
2. If you still can't find the email please visit <https://show.splunk.com> and log in with your splunk.com account.
3. Find the event for this session (look for the session ID, such as PLA1234, SEC5678, etc.) and click on **Enroll event**.

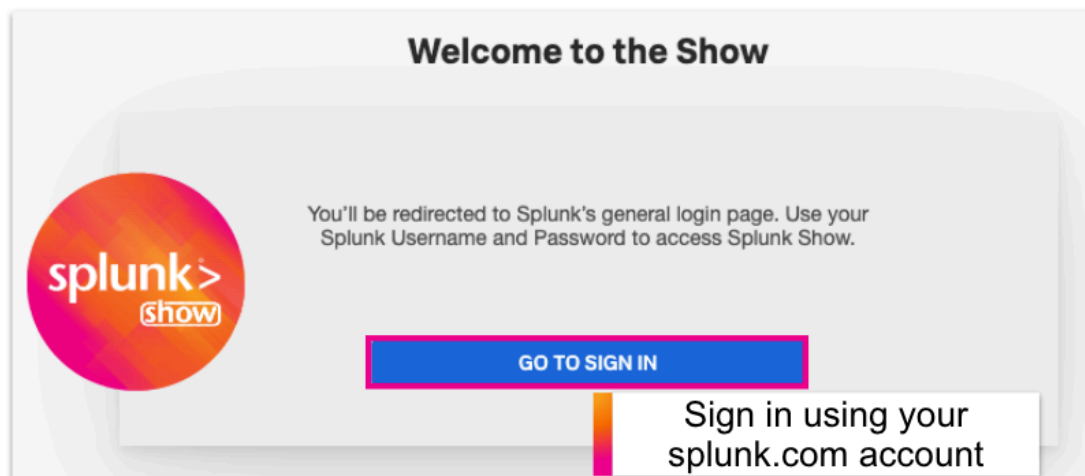


✓ If you **DO** have an email from Splunk Show:

1. Open the email and click on the event link.



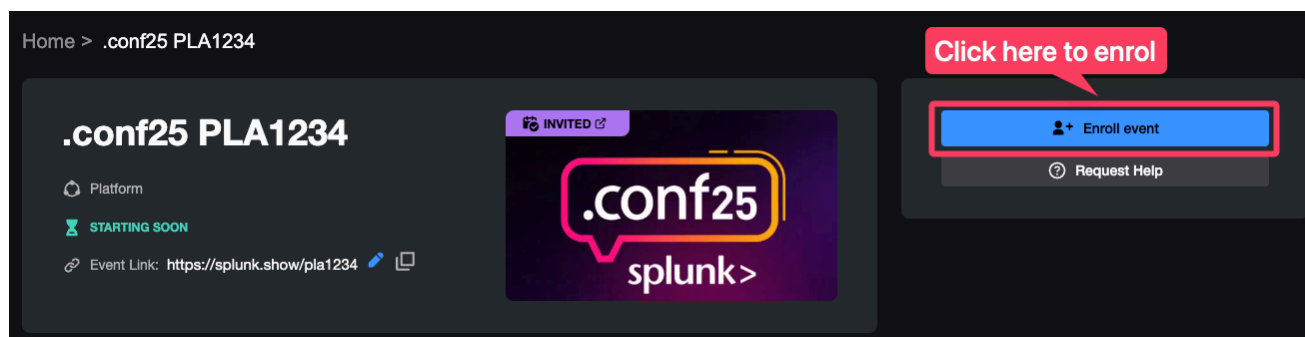
2. On the **Welcome to the Show** page click on **GO TO SIGN IN** and log in using your **Splunk.com** account.



🔑 Don't have a Splunk.com Account?

If you don't already have a Splunk.com account, don't worry - it only takes a few minutes to create one! Please create one [here](#).

3. Once logged in you should see the event page. Click on **Enroll event**.

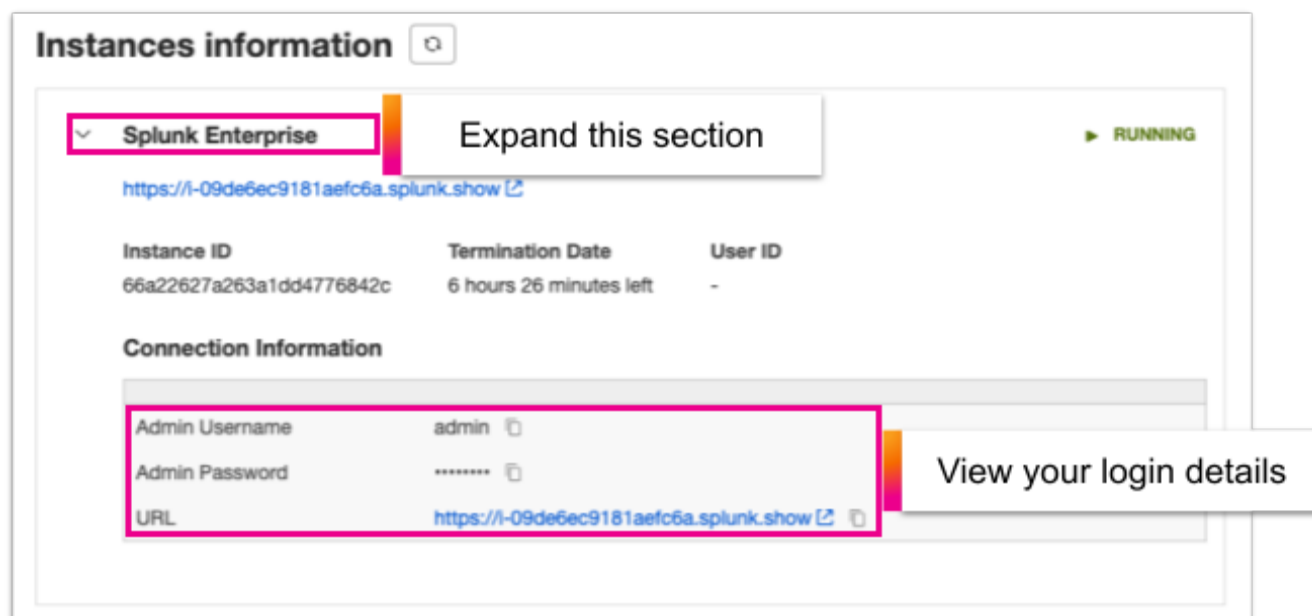


SOS Need help enrolling?

Please ask a member of the onsite support team for assistance.

Finding Your Instance Details:

1. Scroll down the page to the **Instances information** section. Here you will find information on how to access your environment(s) along with the login details.



Note: The screenshot above shows 'Splunk Enterprise' but it may be called something else depending on the environments used in this hands-on session.

Exercise 1 – Dashboard Familiarization and Risk Score Analysis

Description

In this exercise, you will navigate to the User and Entity Behavioral Analytics application to locate and understand risk scores for users in your environment. You will identify Theo as a high-risk user and explore the components that contribute to his elevated risk score.

Steps

1. Click on the User And Entity Behavioral Analytics app

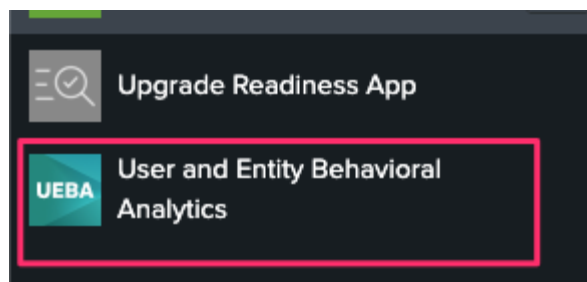


Figure 1.1

2. At the top, you will see the riskiest users and devices listed

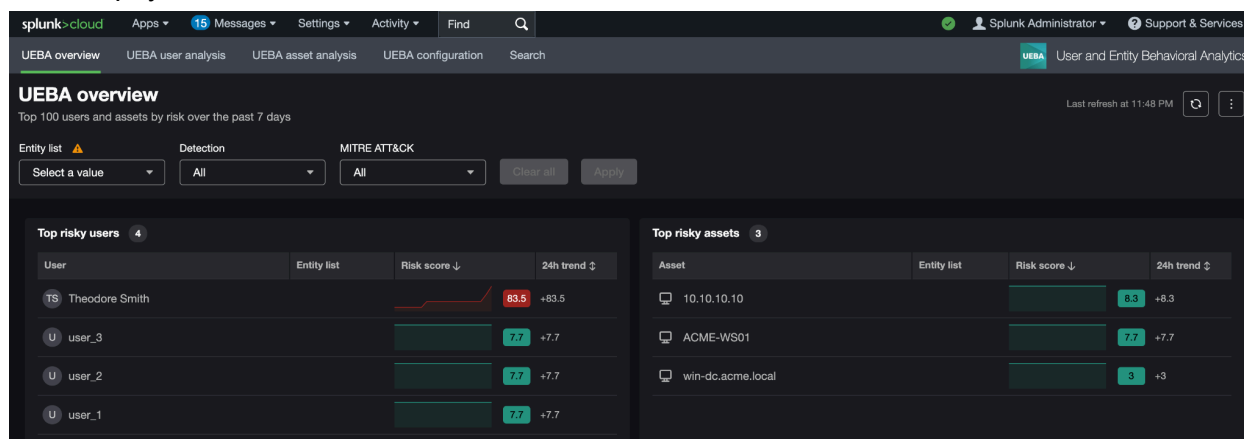


Figure 1.2

3. Explore the dashboard. You can view the detection activities and their associated MITRE tactics and techniques that contribute to the top risky entities near the bottom. Next, examine the top risky user, Theodore Smith, by clicking on his name. You will see information about Theo, including his

business unit, email address, and associated assets.

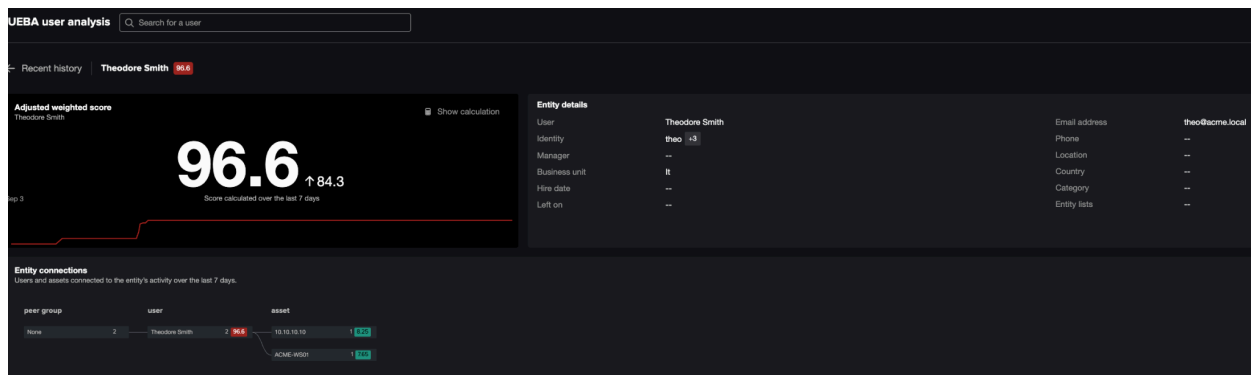


Figure 1.3

- Click on the “Show Calculation” icon in the top right corner of the adjusted risk score box

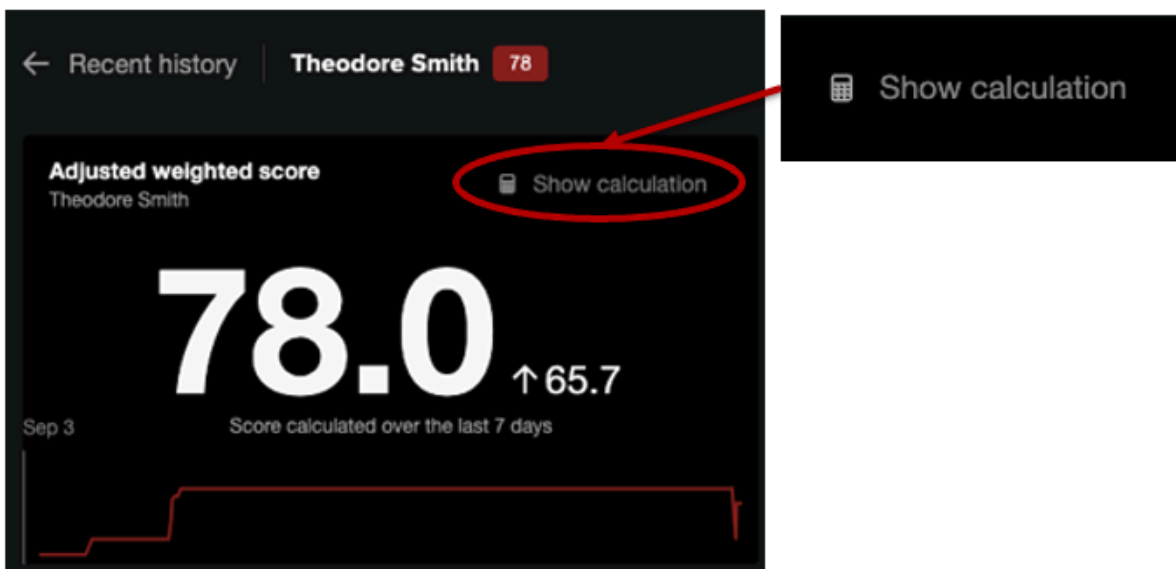


Figure 1.4

- See what has contributed to his risk score

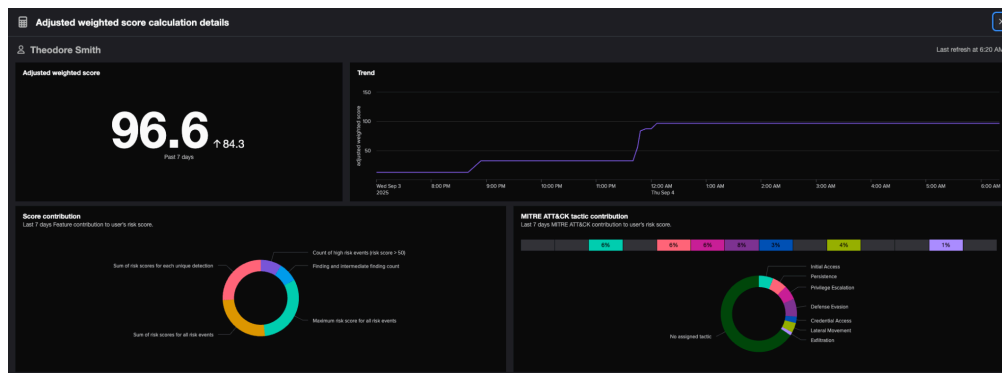


Figure 1.5

- Also, take a look at the other breakdown near the bottom of the page

Entity detection activity 9

Detection name ↕	Score contribution (7d) ↕
UEBA - Rare Windows Process Name by User - Rule	2.1%
UEBA - Password Spraying In Active Directory Data - Rule	5%
UEBA - Unusual Volume of Kerberos TGS Ticket Requests - Rule	5.6%
UEBA - Unusual Volume of Outgoing Emails to Rare Domains - Rule	5.6%
UEBA - Abnormal Group Changes Administrative Activity Model - Rule	5.6%
UEBA - Abnormal Source IP during Administrative Activity Model - Rule	5.6%
/opt/splunk/var/spool/splunk/9a586b967dc56da5_a09396004a220158_events.stash_new	15.3%
/opt/splunk/var/spool/splunk/e1bcf54fb24e3b73_6b4c1061d1723842_events.stash_new	27.6%
/opt/splunk/var/spool/splunk/05fdb0e2a36992c7_f4cabf9ed604c5f2_events.stash_new	27.6%

Figure 1.6

Exercise 2 – Password Spray Attack Detection

Description

You will investigate the initial compromise vector - a password spray attack targeting Active Directory. This exercise shows how extreme value analysis identifies statistically significant authentication anomalies that traditional threshold-based rules might miss.

Steps

1. Return to the main page for Theodore Smith

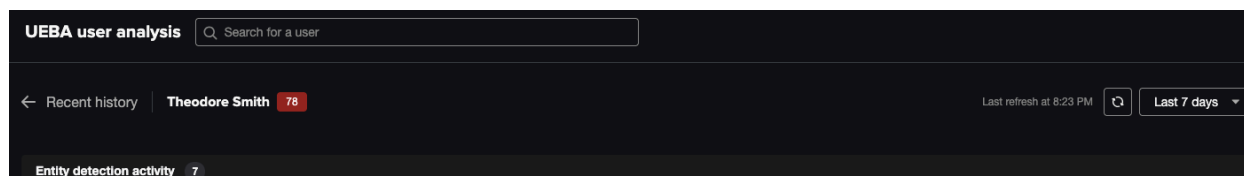
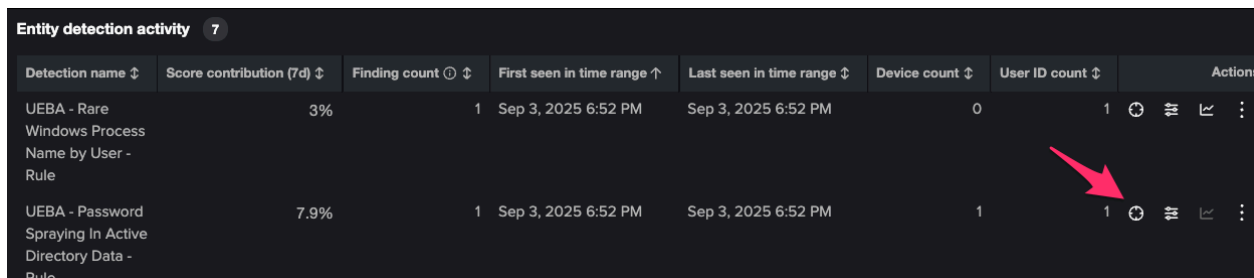


Figure 2.1

2. Scroll down to the Entity Detection Activity, find the UEBA - Password Spraying detection and click on Contributing Risk



Detection name	Score contribution (7d)	Finding count	First seen in time range	Last seen in time range	Device count	User ID count	Actions
UEBA - Rare Windows Process Name by User - Rule	3%	1	Sep 3, 2025 6:52 PM	Sep 3, 2025 6:52 PM	0	1	   
UEBA - Password Spraying In Active Directory Data - Rule	7.9%	1	Sep 3, 2025 6:52 PM	Sep 3, 2025 6:52 PM	1	1	   

Figure 2.2

3. View the Contributing Risk

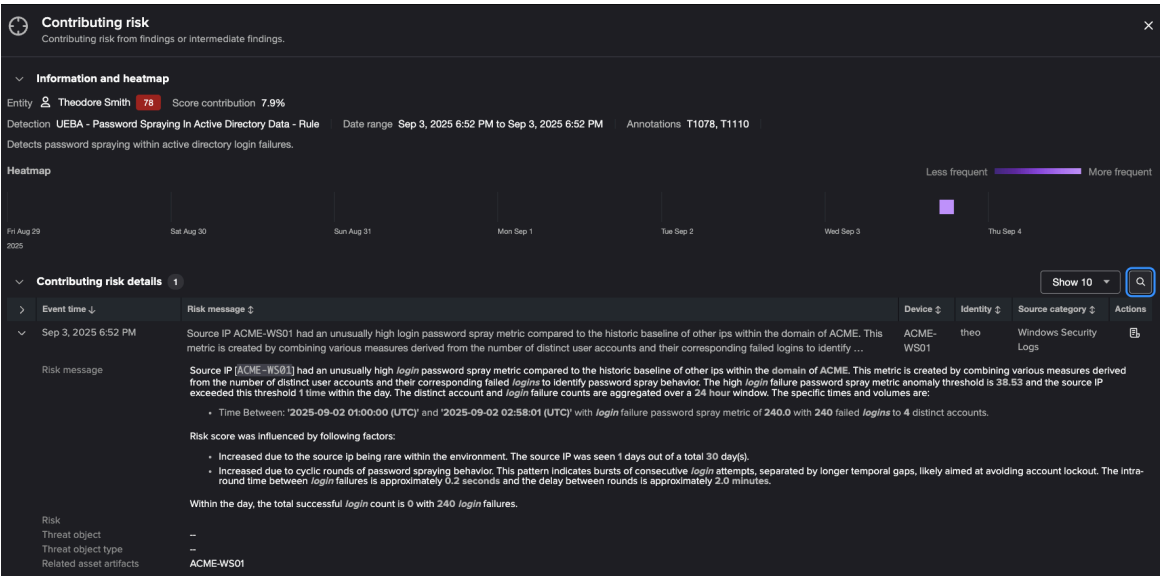


Figure 2.3

Question: How many failed login attempts were observed?

Question: Were there any successful logins?

4. Now examine the raw logs via the View Logs button

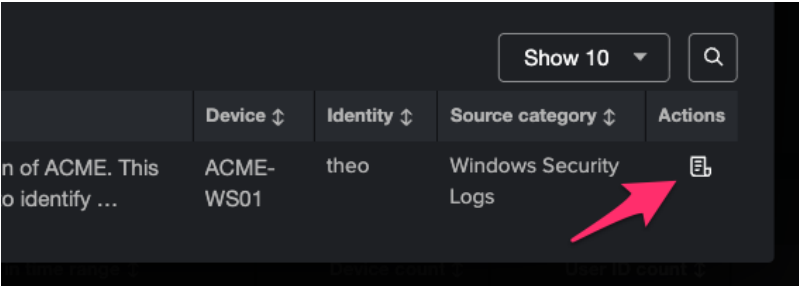


Figure 2.4

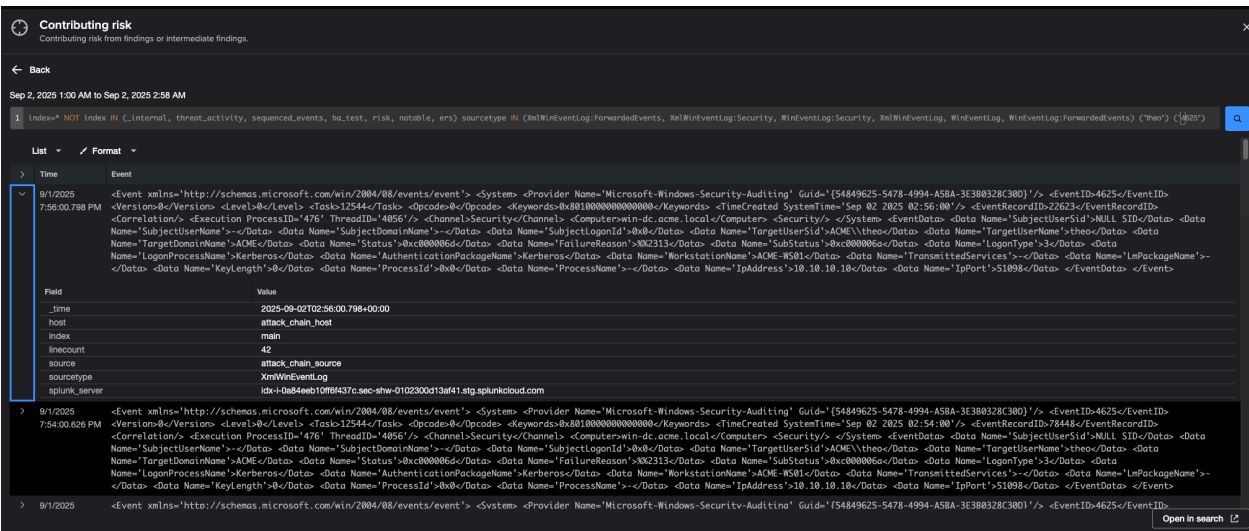


Figure 2.5

Question: Examine the raw logs. What other accounts were targeted?

Question: Does there appear to be a successful login for Theo?

Exercise 3 – Credential Access: Kerberoasting

Description

This exercise focuses on detecting credential access via Kerberoasting.

- The detection focuses on anomalous volumes of TGS ticket requests (Event ID 4769)
- Normal users typically request very few TGS tickets (maybe 5-10 per day)
- Attack pattern shows hundreds of requests in a short time window
- Our model calculates statistical significance relative to historical behavior
- In this scenario, Theo's 50 requests in 10 minutes is a clear statistical outlier
- The attack typically requires running specialized processes/scripts like Rubeus or PowerSploit

Steps

1. Return to the main page for Theodore Smith
2. Focus on Unusual Volume of Kerberos TGS Ticket Requests - Rule
3. Examine the Contributing Risk Scores

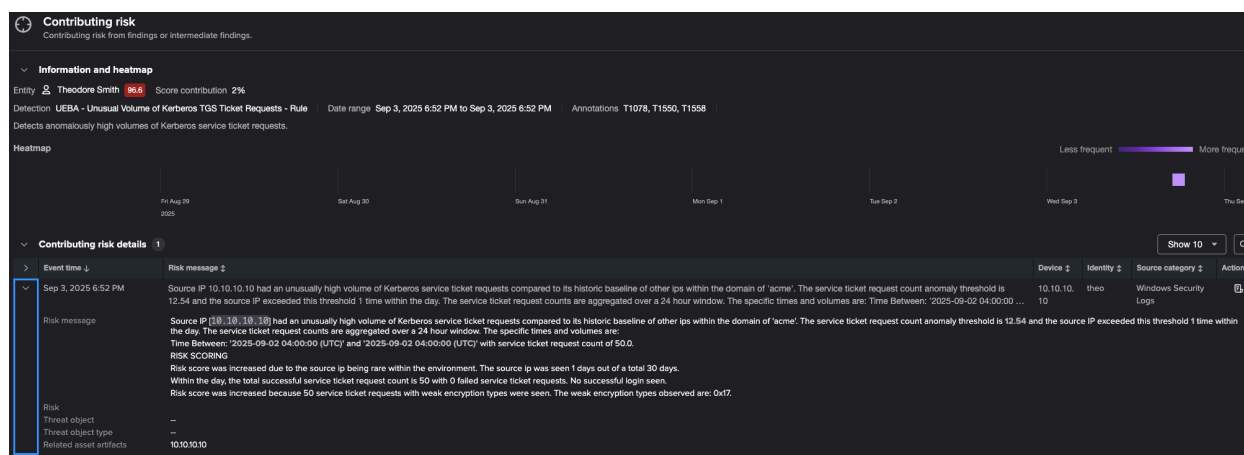


Figure 3.1

Question: What evidence indicates that a script was used in this attack?

Question: What encryption type was requested? Is this suspicious?

Exercise 4 – Rare Process Execution (Tooling)

Description

Investigate how the behavioral analytics engine detected the specialized kerberoasting tool used by Theo.

To perform kerberoasting effectively, attackers typically deploy specialized tools that facilitate the ticket requests and offline cracking. These tools rarely appear in normal business operations.

Technical Details:

- Detection uses probabilistic scoring of process names across the environment
- It's not a denylist - it dynamically identifies what is statistically unusual
- Common tools include Rubeus, mimikatz, PowerSploit, and custom variants
- Both per-user and per-device rarity are calculated to catch different attack scenarios

Steps

1. Return to the main page for Theodore Smith
2. Focus on Rare Windows Process Name by User - Rule
3. Examine the risk events to determine the rare process

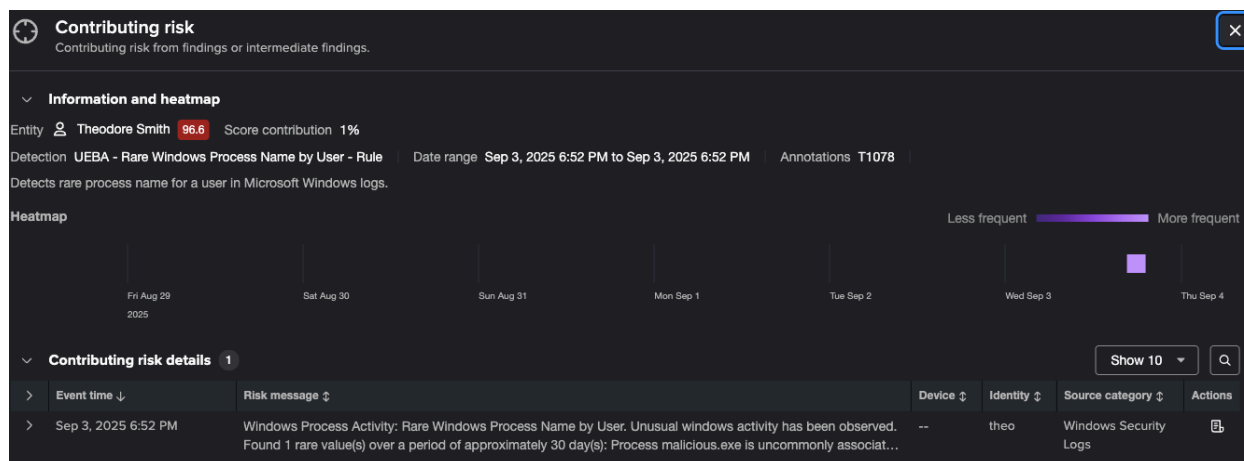


Figure 4.1

4. Examine the baselines for this detection

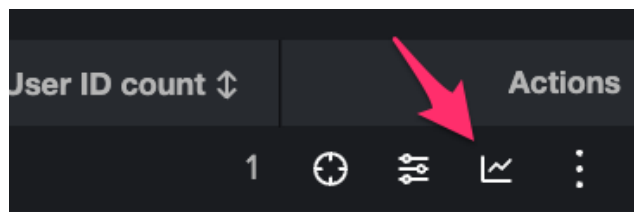


Figure 4.2

View baseline and anomalies ×

Baseline and anomalies by entity and detection

Detection: UEBA - Rare Windows Process Name by User - Rule Entity: Theodore Smith



Anomalous activity: malicious.exe

Windows Process Activity: Rare Windows Process Name by User. Unusual windows activity has been observed. Found **1 rare value(s)** over a period of approximately **30 day(s)**:

[Show more](#)

Anomalous process

Process	Source account	Last seen time	Count	% seen
malicious.exe	theo	09/02/2025, 6:00 AM	1	<0.1%

Common process

Process	Source account	Last seen time	% seen
notepad.exe	theo	09/01/2025, 11:55 PM	100%

Figure 4.3

Exercise 5 – Privilege Escalation and Abnormal Admin Activity

Description

After obtaining credentials through kerberoasting, attackers typically elevate their privileges by modifying group memberships, granting permissions, or creating new privileged accounts. This is a critical transition from access to control.

Technical Details:

- Detection models analyze IAM activity logs for unusual administrative actions
- Features analyzed include: admin activity type, impacted group, source IP, user agent, attached privileges
- Tracks which privileges were granted to which users in which groups
- Abnormal combinations are flagged
- In Theo's case, admin privileges were added to a group outside normal patterns
- Detection uses a combination of historical baselines, and the distribution of historical event counts

Steps

1. Return to the main page for Theodore Smith
2. Examine Abnormal Group Changes Administrative Activity Model - Rule

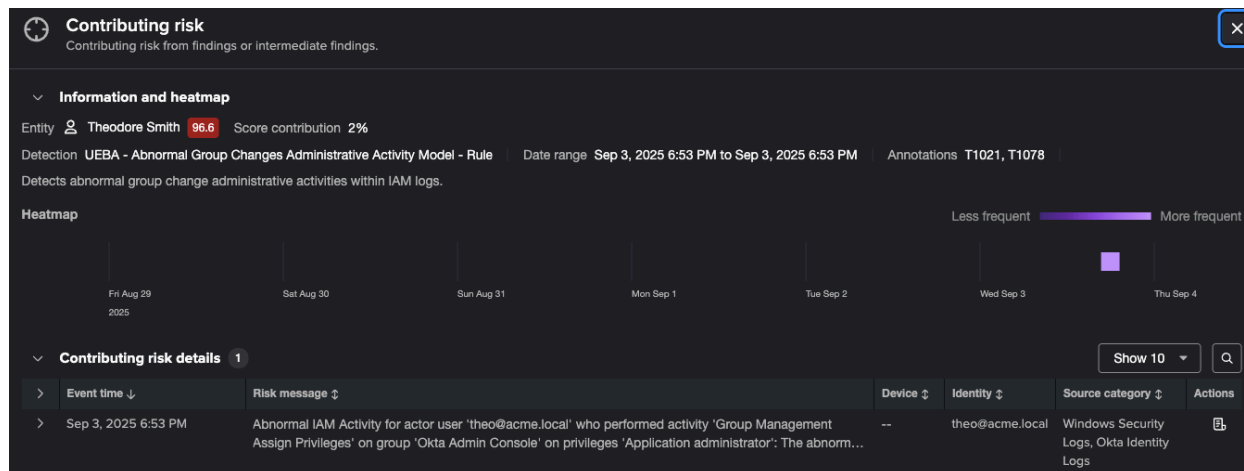


Figure 5.1

Question: What are the two factors that contribute to this anomaly?

3. Now perform a similar analysis on "Abnormal Source IP during Administrative Activity Model - Rule".

Question: What was the "global distribution change"? In this case, the values are quite low.

Exercise 6 – Data Exfiltration

Description

The final stage of the kill chain is the attacker's objective – stealing sensitive data. Email is a common exfiltration channel because it is typically allowed through firewalls and can handle significant data volumes.

Technical Details:

- Detection models analyze Office 365 email logs for anomalous patterns
- Baselines are established for normal email behavior per user
- Two key anomaly types are flagged:
 - Unusual volume of emails to rare or never-before-seen domains
 - Unusually large message sizes
- In this attack, 200 emails sent to external domains (vs. normal 10-15/day)

Steps

1. Return to the main page for Theodore Smith
2. This time, look into the activity timeline via the baselines feature

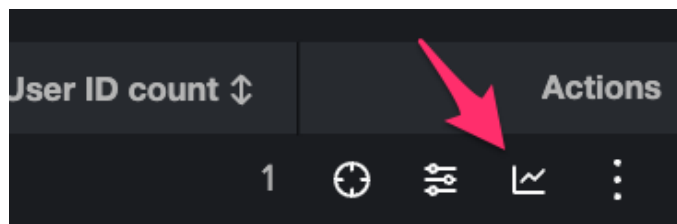


Figure 6.1

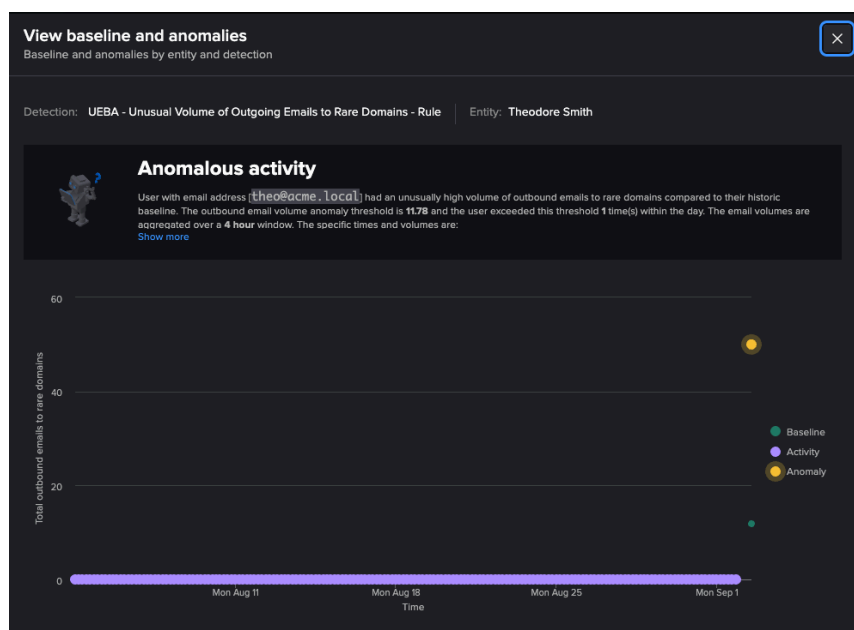


Figure 6.2

Question: What does the baseline tell us? Was the activity level consistent or variable during the baseline period?

Question: Where did Theo exfiltrate data to?

Summary

In this lab, we walked through the entire attack timeline for Theo, and learned more about each of these behavioral analytics detections:

- Password spray - initial access
- Kerberoasting - credential access
- Rare process execution - tooling, in conjunction with kerberoasting
- Privilege escalation/abnormal admin
- Data exfiltration via email to rare domains

We learned how to examine the historical baselines, and how to drill down through the risk events and into the raw events.

Happy Splunking!
